

APEX AI Automated Penetration Test Report

Generated on 2026-10-09 12:48:13 | Target: <https://ptis.scipl.info.in/en/>

Target Host:	https://ptis.scipl.info.in/en/	Overall Risk Rating:	HIGH
Confirmed Vulnerabilities:	5 security finding(s)	Discovered Endpoints:	6 pages & endpoints

Target Application Profile & Context

Application Type:	Authentication & User Login Portal
Identified Purpose:	User authentication and access control interface for Thane Municipal Corporation (██████ ██████████████████) - NTIS UI
DOM Architecture:	1 interactive form(s), Password credentials field (Authentication DOM), 39 script tag(s)

Vulnerability Summary Table

Vulnerability Type	Endpoint	Parameter	Severity	Confidence
Open URL Redirection	https://ptis.scipl.info.in/en/	\$ACTION_REF_1	MEDIUM	100%
Open URL Redirection	https://ptis.scipl.info.in/en/	\$ACTION_KEY	MEDIUM	100%
Open URL Redirection	https://ptis.scipl.info.in/en/	\$ACTION_1:1	MEDIUM	100%
Open URL Redirection	https://ptis.scipl.info.in/login	username	MEDIUM	100%
Cross-Site Request Forgery (CSRF)	https://ptis.scipl.info.in/reset-password	\$ACTION_REF_1	MEDIUM	90%

In-Depth Vulnerability Analysis & Technical Remediation

Finding #1: Open URL Redirection

Finding:	#1: Open URL Redirection [MEDIUM]
Target URL:	https://ptis.scipl.info.in/en/
Parameter:	\$ACTION_REF_1
Trigger Payload:	https://example.com/pentest_verify
Plain Description:	The web application accepts an untrusted URL parameter and uses it to redirect the user to an arbitrary external website.
Root Cause:	Unvalidated redirect destination: The server-side redirection handler (HTTP 302/301 Location header) blindly trusts user-supplied URLs without checking against an allowlist of valid, safe destinations.
Trigger Mechanism:	1. The attacker crafts a link using the legitimate site's domain pointing parameter '\$ACTION_REF_1' to an external attacker-controlled site. 2. The victim clicks the trusted link believing they are visiting the legitimate service. 3. The server sends an HTTP redirect header instructing the browser to navigate to the attacker's destination. 4. The victim lands on an exact replica phishing website and is tricked into entering credentials.
Security Impact:	Highly effective credential phishing attacks that abuse the legitimate domain's reputation to trick users and bypass security filters.
Remediation:	Avoid user-controllable redirect parameters. If required, validate destinations against an explicit strict allowlist of authorized domain names or relative paths.

Finding #2: Open URL Redirection

Finding:	#2: Open URL Redirection [MEDIUM]
Target URL:	https://ptis.scipl.info.in/en/
Parameter:	\$ACTION_KEY
Trigger Payload:	https://example.com/pentest_verify
Plain Description:	The web application accepts an untrusted URL parameter and uses it to redirect the user to an arbitrary external website.
Root Cause:	Unvalidated redirect destination: The server-side redirection handler (HTTP 302/301 Location header) blindly trusts user-supplied URLs without checking against an allowlist of valid, safe destinations.
Trigger Mechanism:	1. The attacker crafts a link using the legitimate site's domain pointing parameter '\$ACTION_KEY' to an external attacker-controlled site. 2. The victim clicks the trusted link believing they are visiting the legitimate service. 3. The server sends an HTTP redirect header instructing the browser to navigate to the attacker's destination. 4. The victim lands on an exact replica phishing website and is tricked into entering credentials.
Security Impact:	Highly effective credential phishing attacks that abuse the legitimate domain's reputation to trick users and bypass security filters.
Remediation:	Avoid user-controllable redirect parameters. If required, validate destinations against an explicit strict allowlist of authorized domain names or relative paths.

Finding #3: Open URL Redirection

Finding:	#3: Open URL Redirection [MEDIUM]
Target URL:	https://ptis.scipl.info.in/en/
Parameter:	\$ACTION_1:1
Trigger Payload:	https://example.com/pentest_verify
Plain Description:	The web application accepts an untrusted URL parameter and uses it to redirect the user to an arbitrary external website.
Root Cause:	Unvalidated redirect destination: The server-side redirection handler (HTTP 302/301 Location header) blindly trusts user-supplied URLs without checking against an allowlist of valid, safe destinations.
Trigger Mechanism:	1. The attacker crafts a link using the legitimate site's domain pointing parameter '\$ACTION_1:1' to an external attacker-controlled site. 2. The victim clicks the trusted link believing they are visiting the legitimate service. 3. The server sends an HTTP redirect header instructing the browser to navigate to the attacker's destination. 4. The victim lands on an exact replica phishing website and is tricked into entering credentials.
Security Impact:	Highly effective credential phishing attacks that abuse the legitimate domain's reputation to trick users and bypass security filters.
Remediation:	Avoid user-controllable redirect parameters. If required, validate destinations against an explicit strict allowlist of authorized domain names or relative paths.

Finding #4: Open URL Redirection

Finding:	#4: Open URL Redirection [MEDIUM]
Target URL:	https://ptis.scipl.info.in/login
Parameter:	username
Trigger Payload:	https://example.com/pentest_verify
Plain Description:	The web application accepts an untrusted URL parameter and uses it to redirect the user to an arbitrary external website.
Root Cause:	Unvalidated redirect destination: The server-side redirection handler (HTTP 302/301 Location header) blindly trusts user-supplied URLs without checking against an allowlist of valid, safe destinations.
Trigger Mechanism:	1. The attacker crafts a link using the legitimate site's domain pointing parameter 'username' to an external attacker-controlled site. 2. The victim clicks the trusted link believing they are visiting the legitimate service. 3. The server sends an HTTP redirect header instructing the browser to navigate to the attacker's destination. 4. The victim lands on an exact replica phishing website and is tricked into entering credentials.
Security Impact:	Highly effective credential phishing attacks that abuse the legitimate domain's reputation to trick users and bypass security filters.
Remediation:	Avoid user-controllable redirect parameters. If required, validate destinations against an explicit strict allowlist of authorized domain names or relative paths.

Finding #5: Cross-Site Request Forgery (CSRF)

Finding:	#5: Cross-Site Request Forgery (CSRF) [MEDIUM]
Target URL:	https://ptis.scipl.info.in/reset-password
Parameter:	\$ACTION_REF_1
Trigger Payload:	GET_STATE_CHANGE
Plain Description:	State-changing actions (like modifying account settings, resetting passwords, or deleting records) can be triggered via simple HTTP requests without requiring an unpredictable anti-CSRF token.
Root Cause:	Missing CSRF tokens & state-changing GET requests: The application performs sensitive state mutations via HTTP GET or fails to validate a unique, cryptographically random Anti-CSRF token on incoming requests.
Trigger Mechanism:	1. A logged-in victim visits an attacker's website or clicks a malicious image tag (e.g.). 2. The victim's browser automatically attaches session cookies to the cross-site request. 3. The vulnerable server receives the request, sees valid authentication cookies, and executes the sensitive action. 4. The action executes without the victim's explicit intention or awareness.
Security Impact:	Unauthorized modification of account settings, unauthorized money transfers, forced password changes, or unauthorized data deletion.
Remediation:	Never execute state-changing operations via HTTP GET. Implement robust anti-CSRF tokens (Synchronizer Token Pattern) for all POST/PUT/DELETE forms, and set SameSite=Lax or SameSite=Strict on all session cookies.

Discovered Application Endpoints

/search
/admin
/api/search
/login
/dashboard
/api